

Conecta +

Plataforma para gestionar donaciones de alimentos y recursos entre empresas y organizaciones sociales

[Nombre del estudiante]

Implementación y seguridad · Pruebas y calidad · Cierre y evaluación

EL PROBLEMA

A unas empresas les sobran alimentos y recursos que otras organizaciones sociales necesitan. Falta un canal confiable que las conecte.



Excedentes que caducan

Productos en buen estado que no llegan a nadie a tiempo.



Sin visibilidad

Las organizaciones no saben qué hay disponible ni dónde.



Sin trazabilidad

Nadie registra quién donó, quién recibió y cuándo.

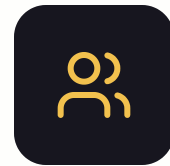
LA SOLUCIÓN

Una red con tres roles



Donador

Publica alimentos o recursos, sigue su estado y ve su impacto: kilos entregados y organizaciones apoyadas.



Beneficiario

Organización social verificada que busca, solicita y confirma la recepción de donaciones.



Administrador

Verifica organizaciones, asigna cada donación y supervisa la red con métricas y auditoría.

FLUJO

El ciclo de una donación



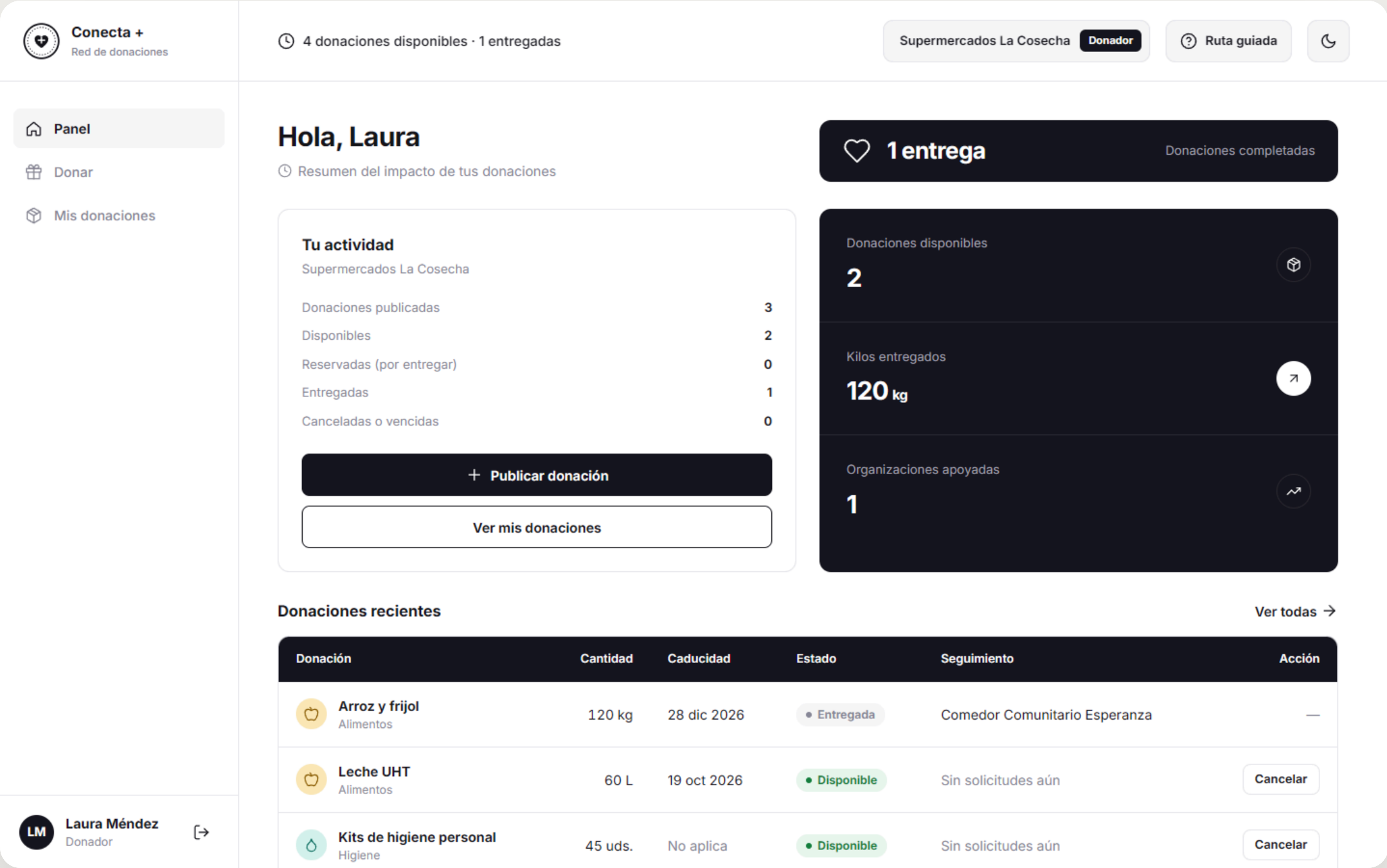
⚡ Al aprobar una solicitud, las demás de esa donación se rechazan solas.

🕒 Si un alimento caduca sin asignarse, pasa a «Vencida» automáticamente.

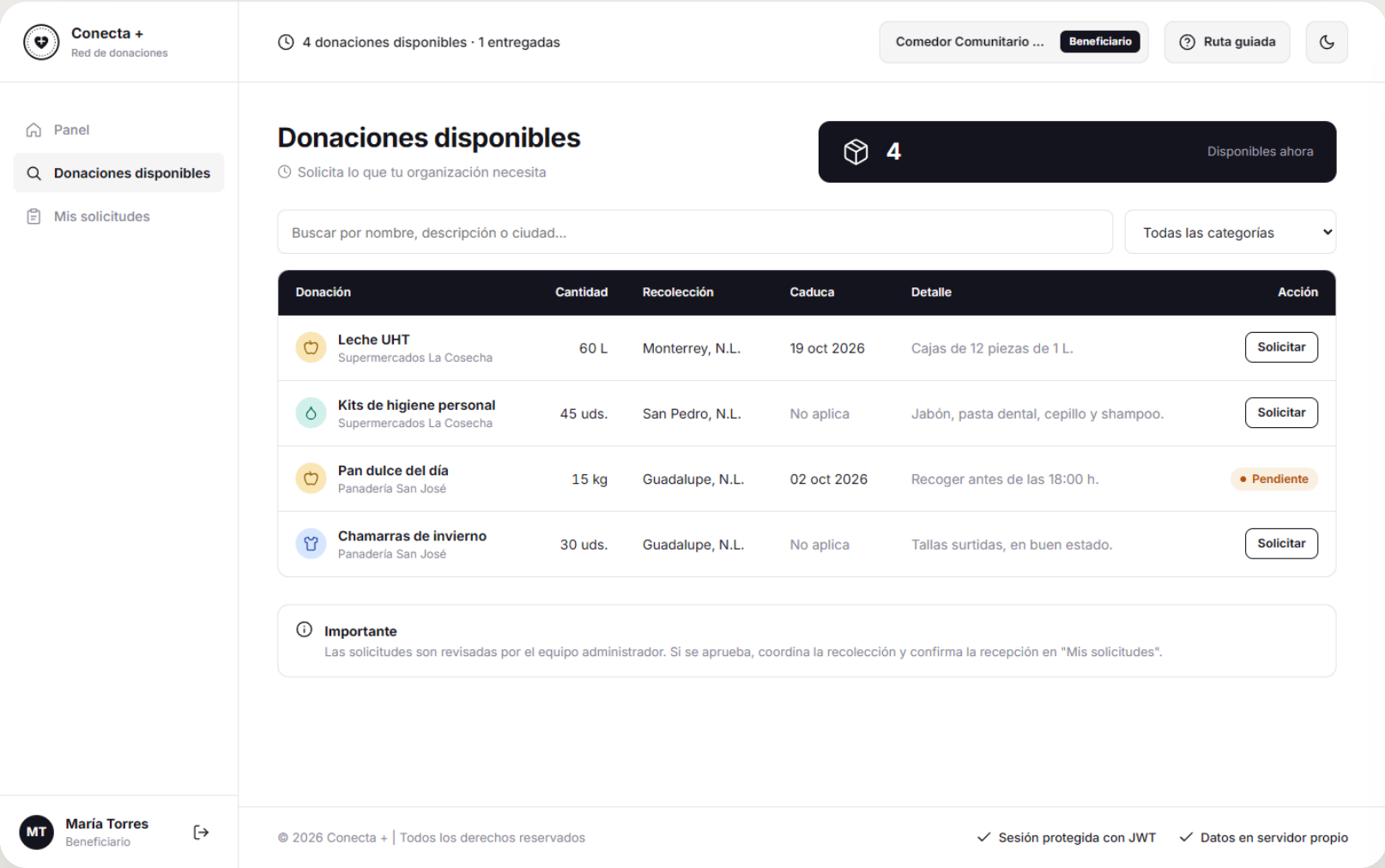
LA APLICACIÓN

Panel del donador

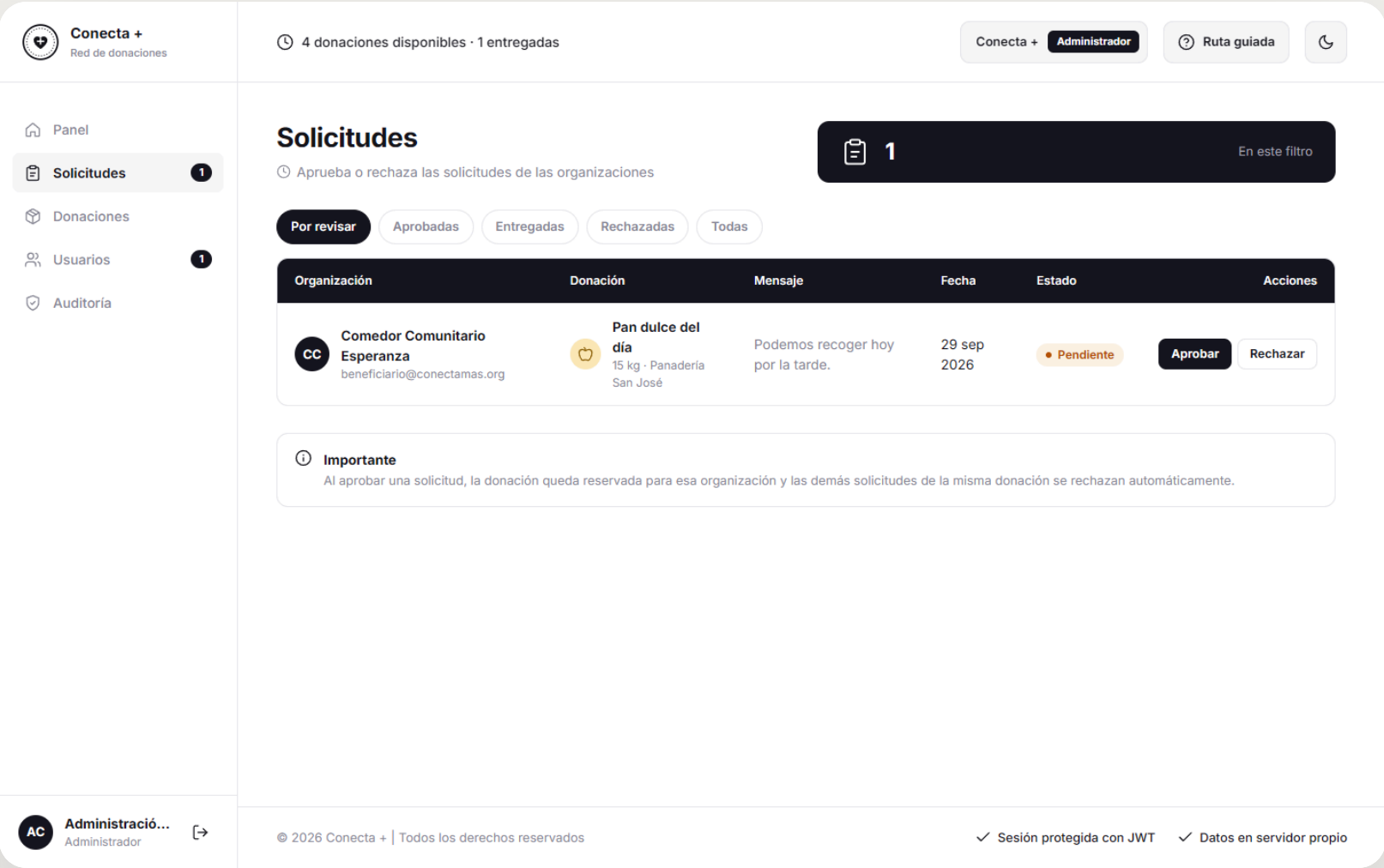
- Impacto en kilos y entregas
- Resumen por estado
- Publicar en un formulario
- Diseño basado en la referencia



Beneficiario y administrador



Beneficiario: busca, filtra y solicita donaciones.



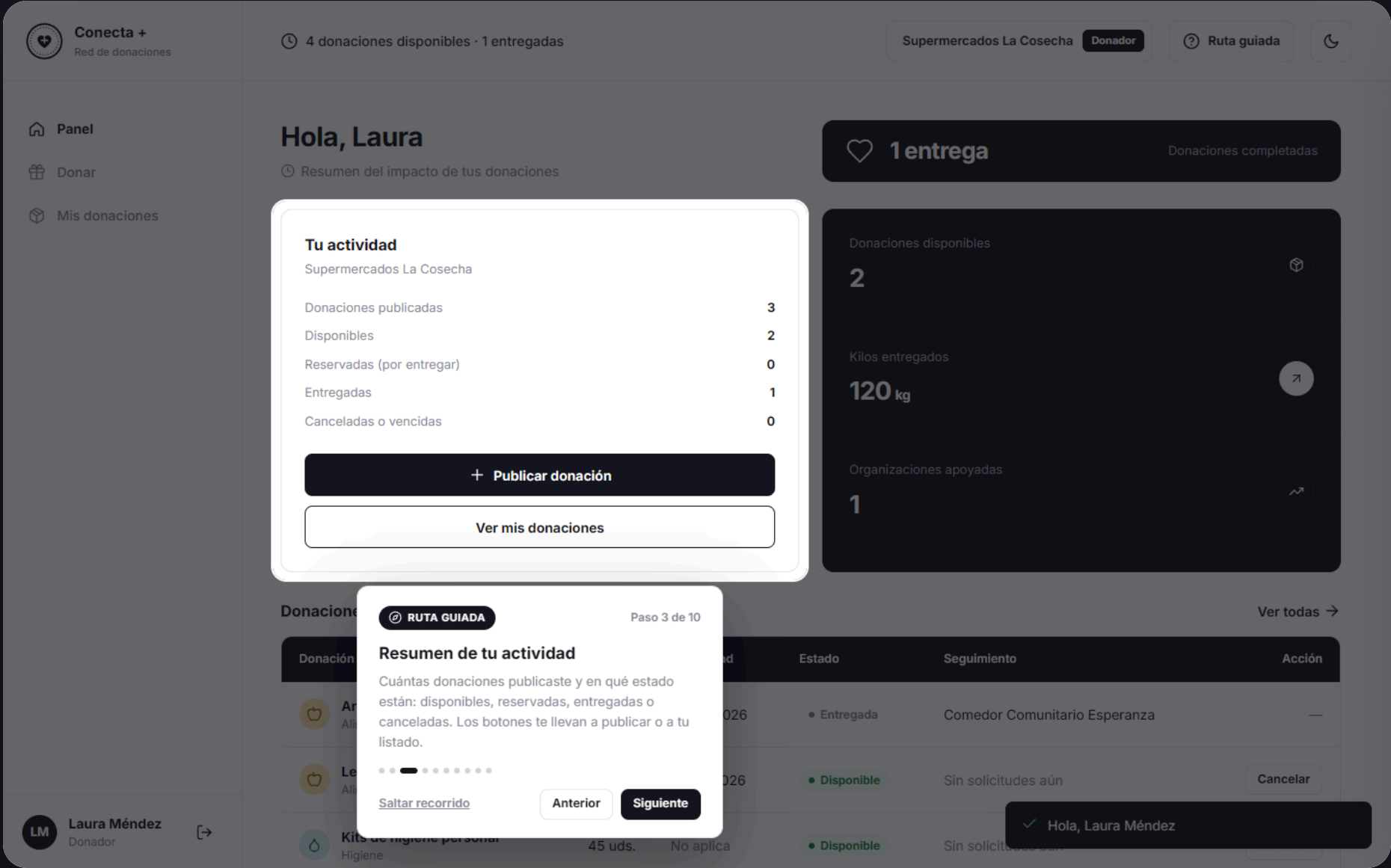
Administrador: aprueba, rechaza o revoca solicitudes.

Ruta guiada en cada panel

Donador · 10 pasos

Beneficiario · 10

Admin · 11



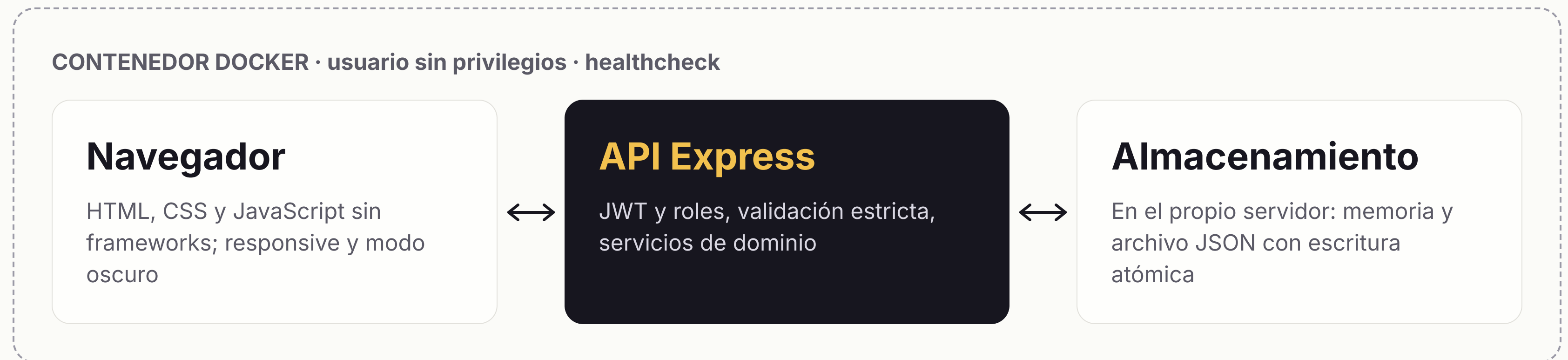
Resalta cada elemento y explica para qué sirve.

Arranca sola la primera vez.

Funciona en móvil y con teclado.

IMPLEMENTACIÓN

Arquitectura sin costos de infraestructura



Sin base de datos ni servicios de pago, como pidió el cliente. Una sola imagen Docker se despliega en cualquier entorno.

Autenticación JWT y controles contra fugas



JWT revocable

Expira en 2 h; cerrar sesión o suspender invalida el token en el servidor.



Cookie httpOnly

JavaScript no puede leer el token; SameSite=Strict frena CSRF.



Fuerza bruta

bcrypt, bloqueo tras 5 intentos y límite de peticiones por IP.



Validación estricta

Rechaza campos extra: nadie se asigna el rol de administrador.



Rol y propietario

Solo ves tus datos; un recurso ajeno responde 404.



Anti-XSS

CSP estricta y el frontend inserta los datos solo como texto.

Pruebas unitarias con Jest

131

pruebas, 0 fallos

99.8%

de líneas

96.9%

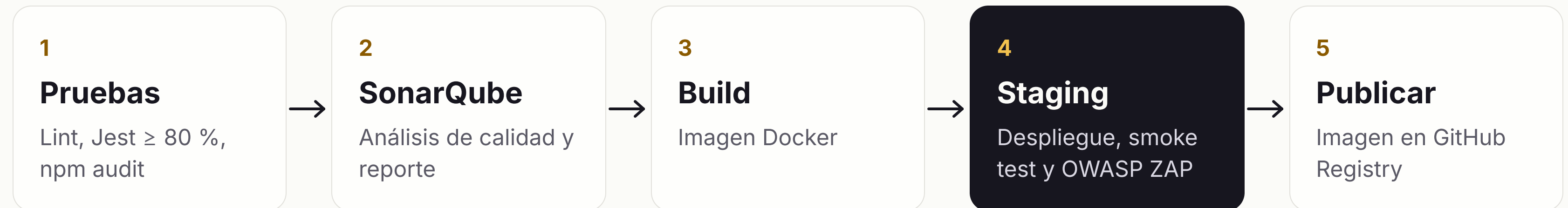
de ramas

99.3%

de funciones

La meta era 80 %, y el pipeline no deja avanzar si baja de ahí. Las pruebas atacan tokens manipulados, escalada de rol, acceso a datos ajenos, XSS e inyección.

Pipeline en GitHub Actions: 5 etapas en verde



Cada push a main despliega automáticamente en un entorno de prueba. Si una etapa falla, la imagen no se publica.

OWASP ZAP: escaneo activo con sesión iniciada

0/0

alertas de riesgo alto / medio

Pasaron SQL injection (6 variantes), XSS reflejado, persistente y DOM, inyección de comandos y path traversal.

Hallazgo	Riesgo	Acción
Content-Type inesperado en métodos no GET	Bajo	Corregido: 405 en JSON
Comentario sospechoso en JS	Info	Corregido
Contenido no almacenable	Info	Intencional: no-store
Uso de localStorage	Info	Solo tema y ruta vista

SonarQube: antes y después de corregir

Métrica	Inicial	Final
Calificación de seguridad	C	A
Vulnerabilidades	1	0
Code smells	8	0
Deuda técnica	40 min	0 min
Bugs	0	0
Cobertura · duplicación	98.4 % · 0 %	98.4 % · 0 %



La vulnerabilidad

Una contraseña de demostración estaba escrita en el código. Ahora vive en configuración y se genera al azar si falta.

Planificado frente a ejecutado

Fase	Plan	Real	Variación
Implementación y seguridad	4 h	7.25 h	+81 %
Pruebas y calidad	3 h	2.75 h	-8 %
Cierre y evaluación	2 h	2 h	0 %
Total	9 h	12 h	+33 %

- ## ¿Por qué?
- El alcance pasó de 2 a 3 roles
 - La interfaz no estaba estimada
 - El cliente pidió la ruta guiada
 - El primer pipeline falló en SonarQube

Lo que haríamos igual y lo que cambiaríamos

1 · Seguridad desde el diseño

Validación estricta y frontend sin innerHTML:
ZAP no halló riesgos medios ni altos.

2 · Configuración fuera del código

Una contraseña de demo en el código bajó la
seguridad a C en SonarQube.

3 · Probar el pipeline pronto

Las diferencias entre Windows y Linux (rutas,
permisos) solo aparecieron en CI.

4 · Validar con el cliente temprano

La ruta guiada surgió al final; revisarlo antes
habría permitido planificarla.

Acciones con metas medibles

Acción	Indicador	Meta	Plazo
Pruebas E2E del frontend con Playwright en CI	Flujos críticos cubiertos	100 % de 8 flujos	1 mes
Quality Gate más estricto	Seguridad Sonar · alertas ZAP	A · fallar ante riesgo medio	2 semanas
Notificaciones por correo	Tiempo solicitud → decisión	< 24 h	1 mes
Alertas de caducidad próxima	Donaciones vencidas	< 5 % al mes	2 meses
Migrar a SQLite o PostgreSQL	Donaciones al mes · p95	> 1 000 · < 300 ms	Según demanda

IA para predecir futuras donaciones

Predicción de la oferta

Series temporales por categoría, zona y temporada.
Meta: error medio < 20 % a 4 semanas.

Emparejamiento inteligente

Sugerir la mejor organización para cada donación.
Meta: -30 % en tiempo de asignación.

CONECTA +

Gracias.

¿Preguntas?

3 roles con JWT

99.8 % de cobertura

0 riesgos altos o medios

SonarQube A · A · A

github.com/EvanDavidMS/conecta-mas-donaciones